

User story : Conformité réglementaire

Description :

Contexte : L'outil doit garantir à tout moment la conformité aux réglementations en vigueur (RGPD, IFRS 16, audit interne...), afin d'assurer la sécurité, l'audibilité et la légalité du traitement des données personnelles et financières.

Besoin :

En tant qu'administrateur, je souhaite que toutes les données contractuelles et personnelles soient gérées selon les exigences du RGPD, les normes comptables (IFRS 16) et les standards d'audit(ISO 27001, COSO, ITIL...) afin d'assurer la conformité réglementaire, la protection des données et la capacité à répondre à toute demande légale ou de contrôle.

Règles de gestion

- Tous les logs (audit) doivent être horodatés, non modifiables, et conservés pendant la durée légale(1 an).
 - Aucune donnée personnelle ne doit être visible ou accessible sans autorisation explicite (gestion par profils/permissions).
 - L'utilisateur peut demander l'export ou la suppression de ses données personnelles à tout moment (droit RGPD).
 - Les accès aux données personnelles et contractuelles sont restreints et tracés.
-

Critères d'acceptation

Scénario	Critère d'acceptation
Traçabilité des actions (audit)	Tous les logs sont horodatés, non modifiables et consultables par l'administrateur.
Accès restreint	Seuls les profils autorisés peuvent accéder aux données personnelles et financières.
Export/Suppression RGPD	Sur demande, l'utilisateur reçoit un export ou la suppression de ses données dans un délai légal.

SFD : Conformité réglementaire

Nom : Garantir la conformité réglementaire de la plateforme

Description :

Cette fonctionnalité assure la conformité du système avec les réglementations applicables : RGPD pour la protection des données personnelles, IFRS 16 pour la génération des rapports financiers, et exigences d'audit interne. Toutes les actions sont tracées, les accès sont contrôlés par profils, les données sont protégées, et les demandes d'export/suppression sont gérées de façon sécurisée.

Acteurs déclencheurs :

- Administrateur (paramétrage, supervision, gestion des droits)

Acteurs secondaires (IMPACTÉS) :

- Tous les utilisateurs (car sujets au RGPD et aux contrôles)
-

Préconditions (INPUT) :

- L'utilisateur est authentifié et dispose des droits nécessaires pour accéder ou consulter les données sensibles.
 - Les mécanismes de traçabilité sont en place.
 - Un module d'administration/RGPD est accessible pour traiter les demandes.
-

Postconditions (IMPACT) :

- Toutes les actions sensibles sont tracées et archivées.
 - Les données personnelles ne sont consultables que par les profils autorisés.
 - Les demandes d'export ou de suppression sont traitées et tracées.
-

Règles de gestion métier :

- Conservation des logs (horodatage, intégrité, durée légale).
 - Accès restreint et tracé aux données sensibles.
 - Droit à l'export/suppression des données personnelles (conformité RGPD).
-

Scénario nominal (cas de succès) :

1. Un utilisateur effectue une action sensible ; celle-ci est automatiquement tracée dans les logs, horodatée et non modifiable.
 2. Un utilisateur habilité consulte ou exporte une donnée personnelle ou contractuelle, l'accès est contrôlé et archivé.
 3. Un utilisateur fait une demande d'export ou suppression : l'action est traitée manuellement, l'utilisateur reçoit un accusé et la traçabilité est assurée.
-

Scénarios alternatifs :

- **Tentative d'accès non autorisée** : Un utilisateur non habilité tente d'accéder à une donnée ; l'accès est refusé et l'événement est consigné.
 - **Demande RGPD** : L'utilisateur demande l'export/suppression de ses données et reçoit une réponse conforme sous délai légal.
-

Informations diverses :

- Périmètre : toutes les données personnelles, financières et contractuelles.
- Interfaces concernées : Interface d'administration/RGPD.
- Traçabilité : logs d'audit, demandes d'accès/export/suppression archivées.